

복무감사

감사결과보고서

2018. 5.

한국산업기술시험원
감 사 부

목 차

I. 감사실시 개요	1
II. 감사결과	2
1. 감사결과 총괄	2
2. 처분요구와 통보사항	2
(1) 사용자 PC 정보보안 취약항목 시정 (현지시정) 및 교육·홍보 강화 (통보)	4
 [붙임] 감사결과 처분요구사항 처리요령	9

I. 감사실시 개요

1. 감사배경 및 목적

이번 감사는 남북정상회담('18.4.27) 등에 따라 직원들의 업무집중분위기를 조성하고, 정보보안 사고 등의 발생에 대비한 공직기강을 확립하는데 목적을 두었다.

2. 감사대상 및 중점

감사는 전 부서를 대상으로 실시하였으며, 감사범위는 부서별로 사용중인 PC 중 총 63대를 임의로 선정하여 9개 항목의 정보보안 항목을 대상으로 하였다. 감사 중점은 개인정보 및 중요정보 암호화 여부, 정보시스템 반출입 통제 여부, 상용 메일 및 유해사이트 차단여부 등 총 9개 항목을 점검하고 재발방지 하는데 중점을 두었다.

3. 감사실시 과정

이번 감사는 2018.4.27(금)부터 같은 해 5.04(금)까지 내부감사인 1명과 정보전략실 2명이 합동으로 본원 및 지역별 분원(서울,경기)을 불시 점검하고, 정보보안 미흡 PC에 대해서는 현지에서 관련교육 및 시정조치하여 감사를 마감 하였다.

II. 감사결과

1. 감사결과 총괄

감사결과 [표1]과 같이 ‘사용자 PC 정보보안 취약항목 현지시정 및 교육·홍보 강화’ 계 62건을 확인하였다.

[표1] 지적사항 총괄

합 계		경고	주의	현지시정	통보
신분상조치	행정상조치				
-	-	-	-	61	1

2. 처분요구와 통보사항

가. 명세 : 별첨

감사결과 처분요구사항 및 통보사항

현 지 시 정 및 통 보

제 목 사용자 PC 정보보안 취약항목 시정 및 교육·홍보 강화

관 련 부 서 사용자 PC 61대 및 정보전략실

내 용

우리 원에서는 원의 정보통신망을 이용하는 모든 임직원에 대한 관리적, 기술적, 물리적 조치의 정보보호를 위해 ‘정보보호 관리규정’을 두고, 하위 규정인 ‘인력 및 교육관리요령’에 따라 정보전략실에서는 연1회 정보보호 교육계획을 수립·시행하여 임직원의 정보보안 인식을 높이기 위해 노력하고 있다.

임직원은 우리 원 물리적환경 관리지침, 개인정보보호세칙, 정보자산관리 요령, 저장매체 관리지침에 따라 [표1]의 정보보안 항목에 대해서 관리적, 기술적, 물리적 조치를 취해야 한다.

[표1] 정보보안 항목

No	정보보안 항목	관련근거
1	Window OS, S/W 최신 보안패치 설치	물리적환경 관리지침 제24조
2	백신 업데이트	물리적환경 관리지침 제21조
3	CMOS, Window 로그인,화면보호기 PW 설정	물리적환경 관리지침 제4,10조
4	상용메일 차단	물리적환경 관리지침 제7조
5	유해사이트(P2P, 증권사이트 등) 차단	물리적환경 관리지침 제6조
6	비인가 저장매체 접속 차단	저장매체 관리지침 제8조
7	개인정보 및 중요정보 암호화 실시	개인정보보호세칙 제34조
8	USB, 노트북 등 정보시스템 반출입 통제	정보자산관리요령 제10조
9	필수 Agent 설치	물리적환경 관리지침 제20조

그러나, 지난 2018.4.30(금)부터 같은 해 5.04(금)까지 정보전략실 직원 2명과 합동으로 진주본원, 서울본원, 경기본원 총 63대의 사용자 PC를 점검한 결과, [표2]와 같이 상용메일(Naver, Daum 등) 차단, 유해사이트(P2P, 증권사이트 등) 차단, 백신 업데이트, 비인가 저장매체 접속 차단 등의 기술적 조치는 양호하게 유지되고 있으나, 개인정보 및 중요정보 암호화, 정보시스템 반출입 통제는 미흡한 상태로 운영되어 지고 있어 현지에서 미흡한 항목에 대해서 관련교육과 함께 현지시정조치를 완료하였다.

일부 취약한 항목의 원인으로는 정보보호에 대한 중요성, 관심도가 다소 부족한 것으로 판단되어, 기존의 정보보안 교육 및 홍보활동을 개선하여 전 직원이 정보보안 인식 수준과 관심도를 높일 수 있는 방안을 마련할 필요가 있다.

[표2] 총9개의 정보보안 항목 점검 결과(사용자 PC 63대)

No	정보보안 항목	점검결과(대수)		양호 수준	조치
		양호	미흡		
1	Window OS, S/W 최신 보안패치 여부	48	15	76%	현지시정
2	백신 업데이트 여부	62	1	98%	현지시정
3	CMOS, Window 로그인,화면보호기 PW 설정여부	46	17	73%	현지시정
4	상용메일 차단여부	63	0	100%	-
5	유해사이트(P2P, 증권사이트 등) 차단여부	63	0	100%	-
6	비인가 저장매체 접속 차단여부	62	1	98%	현지시정
7	개인정보 및 중요정보 암호화 미실시 여부	22	41	35%	현지시정
8	USB, 노트북 등 정보시스템 반출입 통제 여부	22	41	35%	현지시정
9	필수 Agent 설치 여부	60	3	95%	

조치할 사항 정보전략실에서는

- ① 지역별 점검결과 및 9개 점검항목에 대한 이행 준수 방법 등 전사 피드백 조치를 해 주시기 바라며,
- ② 기존의 정보보안 교육 및 홍보활동을 개선하여 전 직원이 정보보안 인식 수준과 관심도를 높일 수 있는 방안을 마련하시기 바랍니다. (통보)

[별첨]

1. 정보보호관리규정 제8조(정보보호의 준수) 제1항

모든 인력은 정보보호 규정 및 세칙을 준수하여야 한다.

2. 물리적환경 관리지침 제4조(패스워드 관리) 제2항

사용하는 모든 패스워드는 패스워드 정책에 따라 패스워드를 설정한다.

3. 물리적환경 관리지침 제6조(인터넷) 제5항 및 제6항

(제5항) 취급중인 개인정보 및 시험원의 정보가 인터넷 홈페이지, P2P, 공유설정 등을 통하여 시험원 외부에 전송/유출되거나 열람 권한인 없는 자에게 공개/유출을 금한다.

(제6항) 시험원의 업무수행을 위하여 IT보안관리자는 특정 사이트에 대해 인터넷 접속을 금지 할 수 있다.

4. 물리적환경 관리지침 제7조(전자메일) 제1항

시험원에서 외부로 자료를 전송 시 시험원의 E-mail 시스템을 통해 전송하도록 한다.

5. 물리적환경 관리지침 제10조(화면보호기) 제1항

시험원 업무 또는 중요 데이터를 PC등 컴퓨터 화면에 띄어놓고 자리를 이석하는 행위를 해서는 안되며, 이석하는 경우 패스워드 기능으로 보호되는 화면보호기를 작동시키거나 전원을 종료하여야 한다.

6. 물리적환경 관리지침 제18조(정보관리) 제2항

PC내 하드디스크 및 저장매체에 비밀자료 및 개인정보자료 등 중요정보 저장 시 국가정보원에서 검증한 암호알고리즘으로 암호화하여야 한다.

7. 물리적환경 관리지침 제20조(소프트웨어 설치 및 변경) 제1항

사용자의 PC에는 IT보안관리자가 지정한 보안 소프트웨어를 설치하여야 한다.

8. 물리적환경 관리지침 제21조(악성코드 검사) 제1항

모든 직원은 IT보안관리자가 지정한 컴퓨터 바이러스 백신 프로그램을 사용자 PC에 설치하고 백신 프로그램 자동업데이트 기능을 이용하여 항상 최신 바이러스 패턴이 유지되도록 하여야 한다.

9. 물리적환경 관리지침 제24조(패치)

사용자 PC는 윈도우 등 운영체제 자동 업데이트 기능을 사용하여 최신 패치 상태를 유지하여야 한다.

10. 저장매체 관리지침 제8조(USB메모리 등 휴대용 저장매체 보안시스템 운영) 제1항

IT보안관리자는 시험원에서 사용되는 모든 USB메모리 등의 휴대용 저장매체에 대해 자료 유출방지를 위한 보안조치를 취하여야 한다.

11. 저장매체 관리지침 제11조(관리책임자) 제4항

관리책임자는 휴대용 저장매체의 반·출입을 통제하여야 하며, 별도의 서식에 따라 기록하여야 한다.

12. 개인정보보호세칙 제11조(개인정보의 보유) 제2항

수집된 개인정보는 안전하게 보관하여야 하며, 그 목적을 달성한 즉시 파기하여야 한다.

13. 개인정보보호세칙 제34조(개인식별정보 및 비밀번호의 암호화) 제1항

개인정보처리자는 수집된 개인정보 중 고유식별정보(주민등록번호, 여권번호, 운전면허번호, 외국인등록번호) 및 신용카드번호와 개인바이오정보, 은행계좌 정보는 안전한 알고리즘으로 암호화 하여 저장하여야 한다.

14. 정보자산관리요령 제10조(정보자산의 반출) 제2항

정보자산은 해당 자산을 관리하고 있는 단위 부서장의 승인 없이 외부로 반출되어서는 안된다.

[붙임]

감사결과 처분 요구사항 처리요령

1. 처분요구사항의 조치기한은 아래와 같습니다.

- 변상명령은 3개월 이내 조치
- 문책 사항은 1개월 이내 조치
- 경고, 주의 사항은 10일 이내 조치
- 시정요구사항은 1개월 이내, 개선, 권고, 통보사항은 2개월 이내 조치

2. 조치결과 통보는 아래와 같습니다.

- 처분요구사항에 대해서는 제1항의 조치기한에 따라 이행을 완료하고 그 결과를 완료 후 15일 이내에 감사부에 통보하여야 함(내부감사규정 제24조 제1항 참조)

3. 이의 신청 및 적극행정 면책 신청

- 내부감사규정 제24조(감사결과 조치) 제1항 및 제24조의 2(적극행정면책제도)에 따라 감사결과에 따른 이의가 있을 경우, 적극행정 면책 신청 사유가 있을 경우 그 이유를 명백히 하여 관계 증빙서류 등을 첨부하여 조치요구를 받은 날로부터 15일 이내에 신청할 수 있음
[별지1 이의신청서, 별지2 적극행정면책신청서]

4. 상기 처분요구사항은 처분요구일로부터 해당 조치 기일내에 처리 하여 주시고 그 결과를 공문으로 회신하여 주시기 바라며, 해당 조치 기일 이후 이행 여부 확인을 위해 사후관리 감사를 실시할 예정임을 알려드립니다.

[별지1] 감사결과 처분요구사항에 대한 이의신청서

감사결과 처분요구사항에 대한 이의 신청서

처분요구일자		처분요구종류	
제 목			
처분요구요지			
이의신청사유			
첨부 : 관계증빙서류 사본 ○○매 끝 . ○○○○년 ○○월 ○○일 이의신청자 ○ ○ ○ (인) 감 사 귀 하			

[별지2] 적극행정 면책 신청서

적극행정 면책 신청서

적극행정면책 신청 요지		
구체적 판단기준 내용	해당 여부	첨부서류
1. 업무처리의 공공의 이익 여부		
2. 업무의 적극적 처리 여부		
3. 업무처리 결과 발생 여부		
4. 고의나 중대한 과실 존재 여부		
가. 자체감사를 받는 사람과 대상 업무 사이에 사적인 이해관계가 없을 것		
나. 대상 업무의 처리에 필요한 자료 또는 정보를 충분히 검토하였을 것		
다. 법령에서 정한 행정절차를 거쳤을 것		
라. 결재권자의 결재를 거쳤을 것		
5. 기 타		

「공공감사에 관한 법률」 제23조의2, 같은 법 시행령 제13조의3 및 제13조의4, 내부감사규정 제24조의2에 따라 적극행정면책을 받기 위하여 위와 같이 신청합니다.

년 월 일

신청인 소속 직책(직급) 성명

감 사 귀 하